Veille Technologique — Écosystème Python

Édition du 28 septembre 2026

Vue d'ensemble

À **trois jours de la sortie stable de Python 3.15.0** (1er octobre), la semaine est marquée par une alerte de sécurité majeure sur CPython : **CVE-2026-82049 (CVSS 8.4 / High)** sur le module `tarfile` affecte toutes les versions ⩽ 3.13 et n'est pas backportée — une forte incitation à migrer vers 3.14/3.15. Du côté de l'outillage, **uv 0.12.18** corrige une vulnérabilité de traversée de répertoires sur Windows, **Poetry 2.5.0** introduce son désinstalleur natif et le support de Python 3.15, et **Polars 2.0 RC.1** positionne le moteur streaming comme moteur LazyFrame par défaut avec une accélération annoncée de 5×. Côté calendrier futur, l'**Alpha 1 de Python 3.16** est prévue le **13 octobre** — soit dans 15 jours seulement.

> **Note de continuité** : Le rapport du 21 septembre couvrait Python 3.15 RC2, la PEP 828 (acceptée pour 3.16), les élections PSF Board et Packaging Council, CVE-2026-39892 (cryptography, buffer overflow), CVE-2026-50269 (aiohttp, header injection), uv 0.12.16–17, la révision des statistiques PyPI (−39%), la PEP 836 JIT (toujours en Draft) et pnpm 12.5 avec support workspaces Python. Cette édition couvre exclusivement les développements survenus depuis le 22 septembre, ou non traités dans les éditions précédentes.

---

1. Sécurité — Deux CVE Critiques sur le Module `tarfile` de CPython

1.1 CVE-2026-82049 — Hard Link vers Symbolic Link (CVSS 8.4 / High) ⚠️

CVE-2026-82049 est la vulnérabilité la plus sérieuse de la semaine. Elle affecte le module `tarfile` de CPython et permet à une archive TAR malveillante de **modifier des permissions ou des fichiers en dehors du répertoire d'extraction**, ou d'**exposer le contenu de fichiers** de l'arborescence cible.

Attribut	Valeur
CVSS v4.0	8.4 (High)
CWE	CWE-59 — Improper Link Resolution Before File Access
Versions affectées	CPython ⩽ 3.13 (toutes versions)
Correctif	Inclus dans CPython ⩾ 3.14.0b1 et dans 3.15.0
Annonce sécurité	14 septembre 2026 (security-announce@python.org)

Mécanisme : les filtres d'extraction de `tarfile` (introduits pour sécuriser l'extraction via les paramètres `filter='data'` / `filter='tar'`) ne traitaient pas correctement les archives contenant **un lien matériel (`hardlink`) pointant vers un lien symbolique (`symlink`)**. Cette combinaison permettait à l'archive de contourner les contrôles de sécurité et d'accéder à des fichiers en dehors du répertoire de destination.

Contexte : les filtres d'extraction `tarfile` avaient été introduits précisément en réponse au CVE anterior Portée à CWE-22 de 2022. Ce nouveau vecteur démontre que la composition hardlink+symlink constituait un angle mort dans la logique de filtrage.

Qui est exposé ? Toute application Python qui :

- Extrait des archives TAR provenant de sources non fiables
- Utilise les versions de CPython 3.13 et antérieures
- Même avec `filter='data'` ou `filter='tar'` activé

Actions recommandées :

```bash
# Vérifier votre version CPython
python --version

# Migration recommandée vers 3.14 ou attendre 3.15.0 (1er oct)
# Pour les versions encore en support, surveiller les security releases
```

Le PR de correction sur le dépôt CPython est #157192. Des backports vers les versions maintenues (3.13, 3.12) sont à anticiper dans les prochaines security releases.

> **Sources :** CVE-2026-82049 — Strix.ai | Annonce security-announce@python.org | OpenCVE

1.2 CVE-2026-87910 — Filter Bypass sur Link Fallback dans `tarfile` (CVSS 5.7 / Medium)

CVE-2026-87910 est une seconde vulnérabilité sur le même module `tarfile`, publiée le 22 septembre 2026. Elle est de sévérité moindre mais de mécanisme distinct.

Attribut	Valeur
CVSS	5.7 (Medium)
CWE	CWE-22, CWE-59
Versions affectées	CPython < 3.15.0
Correctif	Inclus dans CPython 3.15.0

Mécanisme : sur les systèmes ne supportant pas les liens symboliques ou matériels, `tarfile` bascule en mode "fallback" et extrait le membre référencé comme fichier ordinaire. Dans ce cas, **la fonction de filtre était exécutée deux fois** : une première fois pour le membre extrait, une seconde avec `name` pointant vers la destination du lien — mais l'une des deux valeurs de retour était ignorée. Si la première invocation retournait `None` (demandant d'ignorer le membre), la seconde pouvait malgré tout autoriser l'extraction.

Correction : le patch impose que si l'une ou l'autre des deux invocations du filtre retourne `None`, le membre est systématiquement ignoré.

> **Sources** : CVE-2026-87910 — OSV | Strix.ai | Ubuntu Security

---

1.3 CVE-2026-15310 — Épuisement Mémoire (DoS) via Archives ZIP Compressées

Signalée le 17 septembre 2026, **CVE-2026-15310** affecte le module de décompression ZIP de CPython avec les algorithmes bzip2, LZMA et Zstandard. Des archives ZIP malveillantes peuvent provoquer un **épuisement mémoire** en manipulant les paramètres de décompression contrôlés par l'attaquant, entraînant un déni de service.

Le CVSS n'est pas encore définitivement publié au moment de la rédaction. Aucun CVE de ce numéro dans l'annuaire standard n'a encore de patch backporté documenté publiquement ; la correction est incluse dans 3.15.0.

---

2. Outillage — `uv` 0.12.18–0.12.19 : Correctif de Sécurité Windows

2.1 `uv` 0.12.18 — Traversée de Répertoires sur Windows (GHSA-2cv4-cqwr-gwf7)

La version **0.12.18** de `uv`, publiée dans la semaine du 22 septembre, corrige une **vulnérabilité de traversée de répertoires** lors de l'installation de wheels sous **Windows uniquement**.

Mécanisme : lors de l'installation d'une wheel sur Windows, uv ne validait pas suffisamment les chemins de fichiers internes, permettant à une wheel malveillante d'écrire des fichiers en dehors du répertoire d'installation cible.

Impact : tout utilisateur de uv sur Windows installant des packages depuis des sources non fiables (index privés non vérifiés, wheels artisanales) était potentiellement exposé. Les utilisateurs de PyPI via les hashes vérifiés étaient protégés de fait.

Correctif :

```bash
pip install --upgrade uv
# ou
uv self update
# Vérifier : uv --version (doit afficher >= 0.12.18)
```

Autres nouveautés de 0.12.18 :

- Ajout des options `--check` et `--output-format json` aux commandes `uv pip install` et `uv pip sync`, permettant une intégration CI plus riche (vérification sans installation, sorties parsables)

2.2 `uv` 0.12.19 — Version Mineure

La version **0.12.19** apporte des corrections de bugs mineures sans changement fonctionnel majeur documenté publiquement à ce jour.

> **Sources :** This Week in Package Management: 26 Sept 2026 — nesbitt.io | daily.dev

---

3. Poetry 2.5.0 — Désinstalleur Natif et Python 3.15

Poetry 2.5.0, publié le **19 septembre 2026**, représente une mise à jour de fond plutôt qu'une révolution fonctionnelle, mais plusieurs changements méritent l'attention des équipes qui utilisent Poetry en production.

Désinstalleur Natif (`installer.builtin-uninstall`)

Le changement le plus structurant est l'introduction d'un **nouveau paramètre de configuration :**

```toml
# pyproject.toml
[tool.poetry]
# ...

# poetry.toml
[installer]
builtin-uninstall = true
```

Avec ce paramètre activé, Poetry désinstalle les packages **sans déléguer à pip**. Cela réduit la surface de dépendance sur pip pour les opérations de désinstallation et accélère légèrement ces opérations dans les environnements où pip n'est pas directement disponible (images Docker minimales, par exemple).

Support Python 3.15

Poetry 2.5.0 prend officiellement en charge **Python 3.15**, ce qui était attendu pour permettre l'usage de Poetry dans les projets ciblant la nouvelle version majeure dès sa sortie le 1er octobre.

Sécurité — Fin de la Transmission de Credentials sur HTTP

Poetry ne transmettra plus les identifiants configurés pour un dépôt `https` via des connexions `http` non chiffrées. Cette correction de sécurité est particulièrement

pertinente pour les organisations utilisant des registres PyPI privés en environnement mixte HTTP/HTTPS.

Performances

Plusieurs optimisations internes réduisent les temps de démarrage et de résolution :

- Chargement différé de la bibliothèque `requests`
- Mise en cache de la validation du schéma JSON
- Résolution des dépendances avec extras multiples accélérée

Corrections de Bugs Notables

- Résolution correcte des conflits de dépendances avec **marqueurs mutuellement exclusifs** (`python_version < "3.11"` vs `python_version >= "3.11"`)
- `poetry show` affiche désormais les versions correctes dans tous les scénarios
- Chemins relatifs corrigés dans `direct_url.json`

> **Sources** : Poetry Blog — 2.5 | Release 2.5.0 — GitHub

---

4. Polars 2.0 RC — Le Streaming Devient la Norme

Polars 2.0 RC.1, publié le **2 septembre 2026**, représente le changement architectural le plus significatif depuis la 1.0. La version stable est annoncée pour "les semaines suivantes", ce qui la place potentiellement en octobre 2026.

Le Streaming Engine Devient le Moteur par Défaut

Le changement majeur : le **moteur de streaming** est désormais le moteur d'exécution par défaut pour toutes les requêtes `LazyFrame`. Jusqu'à la série 1.x, le streaming devait être activé explicitement (`collect(streaming=True)`).

Impact en termes de performances :

- Gain annoncé : **~5× plus rapide** sur les benchmarks internes
- Réduction significative de la **consommation mémoire**, particulièrement sur les datasets qui ne tiennent pas en RAM

Impact sur l'ordre des lignes : le streaming ne garantit plus l'ordre des lignes dans les résultats. Polars 2.0 rend ce comportement **explicite** : les opérations sensibles à l'ordre doivent être signalées avec `.sort()` avant collection. Un nouvel avertissement guide les migrations.

API Plus Stricte — Philosophie "Fail Fast"

Polars 2.0 adopte une approche plus stricte pour détecter les erreurs au plus tôt :

- `is_in` refuse les conversions de types "lossy" (perte de données) qui étaient silencieuses avant

- **Concaténation horizontale** vérifie que les DataFrames ont la même hauteur
- **Casts ambigus** supprimés au profit de méthodes dédiées

Breaking Changes et Migration

Plusieurs paramètres anciens ont été définitivement retirés :

- `id_vars` et `value_vars` dans `melt()` → remplacés par les paramètres de la nouvelle API
- `join_nulls` → comportement modifié

Deux nouvelles exceptions aident à la migration :

- `AttributeRemovedError` — signale les attributs retirés avec pointeur vers la nouvelle API
- `ArgumentRemovedError` — signale les arguments retirés

```python
# Avant (Polars 1.x)
df.lazy().collect(streaming=True)

# Après (Polars 2.0) — streaming par défaut
df.lazy().collect()

# Pour forcer l'ancien moteur si nécessaire
df.lazy().collect(engine="in-memory")
```

> **Sources :** Announcing Polars 2.0 — pola.rs | AlternativeTo | The New Stack

---

5. `ty` — Progression Continue en Beta (v0.0.81)

Le type checker `ty` d'Astral, développé en Rust, a atteint la **version 0.0.81** (15 septembre 2026), maintenant un rythme soutenu de plusieurs releases par semaine. Le projet reste en numérotation 0.x, signalant qu'il n'est pas encore considéré comme stable.

Améliorations Récentes (versions 0.0.77 → 0.0.81, 1er–15 septembre)

Support Pytest : les fixtures pytest sont désormais correctement résolues dans les analyses de types, évitant les faux positifs (`undefined variable`) sur les fonctions de test qui utilisent des fixtures.

Language Server Protocol (LSP) :

- Ajout des **inlay hints** (annotations de type inline dans l'éditeur)
- Support des **scripts PEP 723** (Python scripts standalone avec métadonnées inline)

Diagnostics et auto-fix :

- Messages d'erreur plus précis sur les violations de protocole
- Suggestions de correction automatique étendues

Performance et mémoire :

- Optimisations du moteur d'inférence
- Réduction de l'empreinte mémoire sur les projets larges

Positionnement vs Mypy et Pyright

`ty` cible un positionnement de vitesse maximale (comparable à Ruff pour le linting), mais sans compromis sur la précision des types. La version stable est toujours attendue d'ici fin 2026 selon Astral. Les équipes qui souhaitent évaluer peuvent l'installer via `pip install ty` ou `uv add --dev ty`.

> **Sources :** Releases astral-sh/ty — GitHub | ty — Astral Docs

---

6. Autres Releases Packaging de la Semaine

pipx 1.17.6 : maintenance release sans changement fonctionnel majeur. pipx reste l'outil de référence pour l'installation globale d'applications Python en environnement isolé.

Hatchling 1.32.4 : correction de bugs dans le build backend Hatchling (utilisé par Hatch et de nombreux projets modernes adoptant `pyproject.toml` natif).

> **Source :** This Week in Package Management: 26 Sept 2026 — nesbitt.io

---

7. Calendrier à Venir — Python 3.15 et 3.16

Python 3.15.0 — Sortie le 1er Octobre 2026 (dans 3 jours)

Au moment de la rédaction (28 septembre), Python 3.15.0 n'est pas encore sorti : la version stable en téléchargement sur python.org est toujours **3.14.4**. La sortie est confirmée pour le **1er octobre 2026**.

Pour rappel, les fonctionnalités majeures de 3.15 :

- **PEP 765 :** interdiction de `return` / `break` / `continue` dans les blocs `finally`
- **PEP 649 :** annotations paresseuses par défaut (suppression quasi-totale du besoin de `from __future__ import annotations`)
- **PEP 739 :** format standardisé de l'information de version Python (machine-readable)
- **Windows ARM64 promu Tier 2** (wheels officielles `cp315-win_arm64`)
- Suppression des modules dépréciés depuis 3.11 : `aifc`, `cgi`, `cgitb`, `chunk`, `crypt`…
- **Correctifs des CVE tarfile** (CVE-2026-82049 et CVE-2026-87910) inclus nativement

Actions à anticiper :

```bash
```

```
# Dès le 1er octobre, tester votre projet sur 3.15 :
uv python install 3.15
uv run --python 3.15 pytest
```

Python 3.16 Alpha 1 — 13 Octobre 2026

Quinze jours après la sortie de 3.15 stable, le **cycle de développement de Python 3.16 commence formellement** avec l'Alpha 1 prévue le **13 octobre 2026**.

Jalon	Date
Début développement	7 mai 2026
Alpha 1	**13 octobre 2026**
Beta 1 (feature freeze)	4 mai 2027
Release Candidate 1	27 juillet 2027
Version finale	**5 octobre 2027**

Release manager : Savannah Ostrowski

La PEP 828 (`async yield from`, acceptée le 3 août 2026) est la première fonctionnalité confirmée pour 3.16. L'Alpha 1 ne contiendra probablement qu'un sous-ensemble des fonctionnalités prévues, mais elle ouvre la fenêtre aux premières expérimentations.

> **Sources** : PEP 826 — Python 3.16 Release Schedule | PEP 790 — Python 3.15 Release Schedule

---

8. PEP 836 (JIT CPython) — Toujours en Draft

Aucune évolution formelle sur la **PEP 836** cette semaine. La situation reste identique à celle du 21 septembre : le document est en **statut Draft** avec des discussions actives sur discuss.python.org mais sans convergence ni décision du Steering Council.

Rappel : la décision doit intervenir **avant fin décembre 2026**. En l'absence d'acceptation, le code JIT sera retiré de la branche principale de CPython. L'Alpha 1 de 3.16 (13 octobre) sera un indicateur important : si le JIT est inclus, cela signale une acceptation implicite ou une extension du délai.

> **Sources** : PEP 836 — peps.python.org | Python JIT Frozen — byteiota.com

---

9. À Surveiller la Semaine Prochaine

Court terme (avant le 7 octobre) :

- **Python 3.15.0 stable** (1er octobre) — surveiller l'annonce sur blog.python.org, les wheels tierces (`numpy`, `pandas`, `torch`, `scikit-learn`), et les éventuels bugs de J0
- **Python 3.16 Alpha 1** (13 octobre) — anticiper dans la semaine d'après : présence ou absence du JIT dans l'alpha, premières fonctionnalités visibles
- **Polars 2.0 stable** — la RC.1 est sortie début septembre ; la version stable est attendue "dans les semaines suivantes", ce qui inclut probablement la première quinzaine d'octobre
- **Backports CVE-2026-82049** — surveiller les security releases pour Python 3.13 et 3.12 (les deux versions actuellement maintenues) corrigeant la vulnérabilité `tarfile` CVSS 8.4

Moyen terme :

- **PEP 836 (JIT) — décision du Steering Council** — l'échéance de décembre approche. Les réunions d'automne seront déterminantes
- **ty vers la version stable** — Astral vise fin 2026 ; surveiller un éventuel passage en version 0.1.0 ou 1.0.0
- **Packaging Council — premiers travaux** — maintenant constitué depuis la semaine précédente, les premières prises de décision sont attendues. La PEP 751 (`pylock.toml`, déjà au statut Final depuis mars 2025) devrait être parmi les premiers dossiers

Signaux faibles :

- **Adoption de Python 3.15 par les outils IA** — après le chaos des breaking releases ML en août (openai-python, Anthropic SDK, vLLM, Transformers), les mainteneurs vont-ils publier des wheels `cp315` dès le J0 du 1er octobre ?
- **Polars 2.0 et les projets data Python** — les breaking changes du streaming par défaut et de l'ordre des lignes vont générer des rapports de migration dans les semaines suivantes ; à surveiller sur les issue trackers de pandas-polars bridges et des outils ETL Python

---

Rapport généré automatiquement le 28 septembre 2026 — Veille Python Fréquence : hebdomadaire | Projet Veille technologique